



Auditoría Técnica y Blindaje de Servidores Linux

Proyecto Final: Hardening y Respuesta a Incidente de Seguridad

Martin Gordillo

Octubre 2024

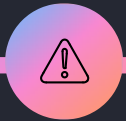
Resumen del Incidente de Seguridad

Fecha del incidente: 8 de octubre de 2024

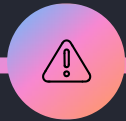
Servidor afectado: Debian con WordPress

Impacto: Compromiso total del servidor

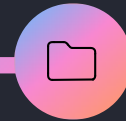
Vulnerabilidades explotadas:



Servicio FTP inseguro
expuesto



Base de datos MySQL sin
autenticación



Permisos 777 en directorios
críticos

Análisis de Vulnerabilidades - Pentesting



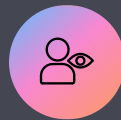
Servicios
innecesarios activos

(FTP, Telnet, Avahi/mDNS)



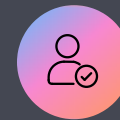
Credenciales
débiles

Y sin política de
contraseñas



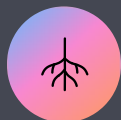
MySQL expuesto

Sin autenticación

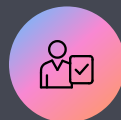


Permisos de archivo
inseguros

(777)



SSH con acceso root permitido



Protocolo Avahi/mDNS

Sin restricciones

Respuesta al Incidente - Acciones de Remediación Inmediata



Aislamiento del servidor de la red



Análisis forense y recolección de evidencia



Limpieza de malware y backdoors



Cierre de puertos inseguros (FTP, Telnet, MySQL)



Restablecimiento de contraseñas



Restauración desde backup limpio

Estrategia de Hardening - Endurecimiento del Sistema



Configuración de PAM

Configuración de PAM (Pluggable Authentication Modules) con SHA-512 y 65,000 rondas.



Deshabilitar acceso root en SSH

Deshabilitar acceso root en SSH (PermitRootLogin no).



Purga de servicios innecesarios

Purga de servicios innecesarios (FTP, Telnet, Avahi).



Configuración de firewall UFW

Configuración de firewall UFW.



Actualización de kernel y parches de seguridad

Actualización de kernel y parches de seguridad.

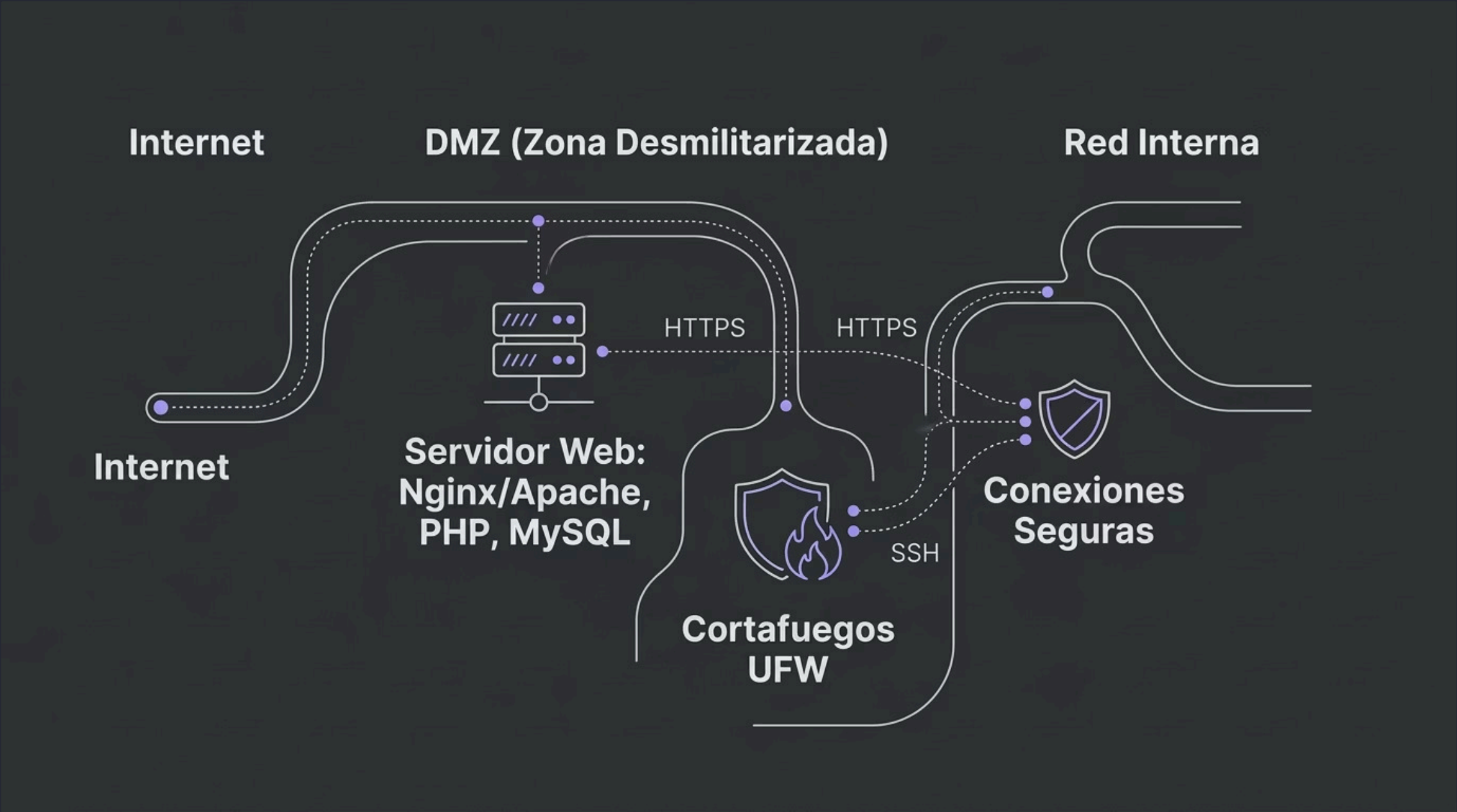


Auditoría y logging centralizado

Auditoría y logging centralizado.

Arquitectura de Red Segura

Una infraestructura de red bien diseñada es fundamental para proteger los activos digitales. Implementamos una arquitectura en capas para asegurar el servidor web y los datos sensibles.



Esta arquitectura segmenta la red para contener posibles brechas. La DMZ actúa como una zona de amortiguación donde reside el stack web (Nginx/Apache, PHP, MySQL), protegida por un firewall UFW. Todas las comunicaciones entre las zonas se realizan a través de canales seguros (HTTPS y SSH), minimizando la superficie de ataque y garantizando la integridad de los datos.

Plan de Continuidad - Disaster Recovery Plan (DRP)

Una estrategia robusta de Disaster Recovery es esencial para minimizar el tiempo de inactividad y la pérdida de datos, garantizando la resiliencia de nuestros sistemas ante cualquier eventualidad.

Estrategia de Backup 3-2-1

- **3 copias de datos:** Asegurando múltiples redundancias de toda la información crítica.
- **2 medios de almacenamiento diferentes:** Diversificando los métodos para reducir el riesgo de fallos simultáneos.
- **1 copia fuera del sitio:** Protegiendo los datos contra desastres locales.

Objetivos de Recuperación

- **RTO (Recovery Time Objective):** 4 horas
- **RPO (Recovery Point Objective):** 1 hora



Frecuencia de Backups

Diarios + incrementales cada 6 horas



Pruebas de Recuperación

Mensuales



Documentación y Procedimientos

Mantenimiento de documentación detallada para procesos de recuperación.

Conclusión y Estado Actual

Hemos transformado el entorno del servidor de una postura de alto riesgo a una infraestructura segura y robusta.

Antes

Seguridad nula, múltiples vulnerabilidades críticas, compromiso total.

Después

Entorno endurecido profesional, cumplimiento de estándares de seguridad.

Logros Alcanzados

Eliminación de todas las vulnerabilidades críticas

Implementación de hardening completo

Plan de continuidad y disaster recovery

Monitoreo y auditoría continua

Recomendaciones Futuras

- Auditorías periódicas de seguridad.
- Actualización continua de políticas de seguridad.
- Capacitación del personal en las mejores prácticas de seguridad.

 SEGURIDAD FORTALECIDA

Recomendaciones Técnicas Futuras

Para mantener una postura de seguridad robusta y proactiva, es crucial implementar las siguientes mejoras y prácticas:



Implementar IDS/IPS

Sistema de Detección/Prevención de Intrusiones para monitorear y bloquear actividades maliciosas.



Configurar SIEM

Gestión de Información y Eventos de Seguridad para análisis centralizado de logs y alertas.



Implementar WAF

Web Application Firewall para proteger aplicaciones web de ataques a nivel de protocolo HTTP.



Establecer política de rotación de contraseñas

Garantizar el cambio regular de contraseñas fuertes para reducir riesgos de compromiso.



Implementar autenticación multifactor (MFA)

Añadir una capa extra de seguridad para el acceso a sistemas críticos.



Realizar auditorías de seguridad trimestrales

Evaluaciones periódicas para identificar y mitigar nuevas vulnerabilidades.



Mantener un programa de parches automáticos

Asegurar que todos los sistemas y software estén siempre actualizados con los últimos parches de seguridad.